Submission supplement

Verifiable Crypto-Erasure for Cross-Border Health Data Audit Trails under the European Health Data Space

Arshad Akhtar Abbasia
MSc in Sustainable Energy Logistics, Faculty of Logistics, Høgskolen i Molde
Supervisor: Prof. João Ferreira
14 November 2026

1 **Reproduce in five minutes**
One page: the commands, the numbers you should see, and where they appear in the thesis.

2 **Verification dossier**
Three hostile reviews of the thesis, a two-pass audit of the code, and a search for prior art: what each found and how each finding was resolved.

3 **Evidence map**
Every load-bearing claim, the section that makes it, the code that checks it and the test that guards it.

4 **Policy brief, English**
Two findings for the Norwegian authorities who will set retention for the cross-border audit trail.

5 **Notat, norsk**
The same brief in Norwegian.

What is submitted

The submission at a glance

The thesis is the examined work. Everything else here lets a reader check it: run the code, see what hostile reviewers found and how it was fixed, follow any claim to the code that tests it, and read what the findings mean for the authorities who will act on them.

Item	Where	What it is for
Thesis	VERA-SNARK_Thesis_SUBMISSION (Word and PDF)	The examined text: seven chapters, Appendices A to D, references.
Live demonstration	trfhimolde.streamlit.app	The examiner's walk over the running code. It reproduces Chapter 5 when opened and shows a notice beside any figure that differs.
Archived code	doi.org/10.5281/zenodo.23989242	Release 1.3.0, the code Appendix A reproduces. All versions: doi.org/10.5281/zenodo.23819274.
This supplement	Five parts, listed below	Material that supports the examination without being part of the examined text.
Repositories	Astheno-sphere/TRF and Astheno-sphere/TRF-thesis	Full history, change trail and inspector. Access for the panel on request.

> Nothing in this supplement adds a claim to the thesis. Where it summarises, the thesis section is named; where it reports a check, the check can be rerun from the archived code.

Part 1

Reproduce in five minutes

Python 3.11 to 3.13; the checker needs only the standard library. The run is deterministic under seed 20260915, so your output matches the thesis byte for byte.

1 **Get the code**

```
git clone https://github.com/Astheno-sphere/TRF && cd TRF
```

or download release 1.3.0 from Zenodo

2 **Run the checker**

```
python3 trf_checker.py
```

standard library only, under a second

3 **Run the tests**

```
pip install -r requirements.txt pytest && python3 -m pytest -q tests/
```

56 passed

4 **Run everything**

```
cd repro_package && ./run_all.sh
```

in the thesis repository; seven diffs, all empty

The fastest single check. The auditor view of record 100 prints its commitment. If it matches, your run is the reported run. `678ade47c1e6dc03…`

What you should see

Result	Value	Thesis
Semantics I, total violations	**95**	Table 5.3
Semantics I, records with a violation	**90 of 200**	Table 5.3
Corollary 1.2 witnesses, no erasure request	**39**	§5.4
Exhaustive cross-check, three conflict cases	**no satisfying assignment**	Table 5.4
Records invalidated (Art. 17 / Art. 68(12))	**138 (52 / 86)**	Table 5.6
Semantics II, total violations	**0**	Table 5.6
Records verifying against the audit log	**200 of 200**	§5.7
Figures changed by real-format Synthea payloads	**none**	Table 5.7
Bounded Z3 check, no counterexample	**9 of 9**	§5.5

Part 2

Verification dossier

Six reviews between 28 October and 6 November 2026, each built to find faults rather than confirm the work. Every finding was reproduced or checked against its source before anything changed, and every change went through a gated patch whose record is in the thesis repository's change trail.

Review	What it attacked	What changed
Red team, round 1 28 Oct 2026	Seven adversaries built to fail the thesis: a cryptographer, a formal-methods purist, a data-protection lawyer, a systems engineer, a logistics professor, a prior-art hunter and a relevance sceptic.	Defence doctrine written for each; research hardened against the live legal flank (current authority located and cited).
Red team, round 2 31 Oct 2026	Independent agents on the revised text: an examiner panel and a consistency and citation audit.	Sub-questions answered one by one in Chapter 7; the legal condition of Corollary 1.2 carried into constraint C3; citations re-verified.
Supervisor review 2 Nov 2026	Prof. Ferreira's feedback, checked item by item before acting; where it was incomplete, the fix went further.	41 verified edits (P102, P103): the two principal interpretive steps named at all nine sites with four subsidiary premises; search counts; retention floor led by the sourced value.
Examiner red team, round 3 2 Nov 2026	An external-examiner attack on the full text: logical soundness, legal reading, method, consistency.	26 verified edits (P109); five argument-level points decided by the author and written in (P112): the policy status of the pilot floor, the dependence of Proposition 1 on Section 4.2, the premise of Corollary 1.2, the identifier case, and what "verifiable" qualifies.
Prior-art and new-law search 2 Nov 2026	Literature and law to November 2026, including Norwegian sources.	No work found that models floor, right and ceiling together. Three updates written in: EDPS v SRB (C-413/23 P), Implementing Regulation (EU) 2026/2083, the designation of Folkehelseinstituttet.
Code audit, two passes 6 Nov 2026	An external review in the style of CodeRabbit, then a deeper read-only hunt for what it missed.	1 critical and 16 major findings, 15 more from the second pass, each reproduced before fixing; every recorded run still byte-identical; release 1.3.0.

> What held throughout: the four propositions, every figure in Chapter 5, and the novelty of modelling the retention floor, the right to erasure and the deletion ceiling together.

The code audit, finding by finding

The critical and major findings of both passes, in the order fault, evidence, fix, and how the fix was verified. The full report, with every minor finding, is CODE_REVIEW.md in the thesis repository.

C1 — Critical

The reproduction README gave the wrong reference commitment for record 100.

Evidence	README said 11087780fd192c8f; the run prints 678ade47c1e6dc03. A correct reproduction would have looked failed.
Fix	Value corrected in both repositories; the integrity table rebuilt row by row from the recorded run.
Verified	Fresh run compared with every value in the table.

P2-C1 — Critical

The first fix for the growing audit log attached records to a log only when first invalidated.

Evidence	Two populations generated before invalidation shared one log; on the server, the cached thesis log grew from 438 to 933 leaves after two other runs.
Fix	The log is bound to each record when it is created; every population starts its own.
Verified	New test: an earlier population's log is untouched by later runs and still verifies.

M1 — Major

The 54 tests cited by the thesis were not in the thesis repository.

Evidence	No tests/ directory in the reviewed clone.
Fix	demo_app/ now carries the tests and the recorded runs.
Verified	56 tests pass from inside the thesis repository.

M2, M6 — Major

Documented reproduction commands failed from the folders they were written for.

Evidence	FileNotFoundError for the Synthea subset; ModuleNotFoundError for the Norwegian module; src/ paths that did not exist.
Fix	Appendix A.5 states where commands run; paths corrected; the realism layer finds the repository's one copy of the subset.
Verified	Every command run from a clean state; run_all.sh diffs clean on all seven.

M3 — Major

The audit log was described as tamper-evident without a limit.

Evidence	The root is recomputed from leaves the log holds; rewriting a leaf yields a consistent root.
Fix	Thesis (§5.7) and code state the scope: divergence between a record and its log is detected; a rewrite of the log needs a published root, specified in §6.1 and not built.
Verified	Wording checked against the code path.

M4 — Major

Semantics II "0 violations" read as a test of C2 and C3.

Evidence	Readability is derived from the invalidation month, so C2 and C3 hold by construction.
Fix	§5.7 names the integrity check as the part of the result that can fail.
Verified	Integrity check shown to fail under each of three tampering cases.

M5 — Major

The exhaustive cross-check answered wrongly when its horizon left retention months unexamined.

Evidence	floor 120, horizon 14 returned feasible for months it never checked.
Fix	The function refuses such a horizon; the checker also compares it with itself on its four cases and fails on disagreement.
Verified	Test; a mutated boundary fails two tests.

M8 — Major

The hosted app grew its audit log with every rerun.

Evidence	Ten runs: 4,380 leaves; a 200-record sweep went from 0.71 s to 3.44 s.
Fix	One log per population (see P2-C1).
Verified	Ten runs leave 438 leaves; the test suite runs in 13 s instead of 22 s.

M9 to M11 — Major

Deployment and reproduction READMEs carried superseded figures and table numbers.

Evidence	35 and 940 bytes; Tables 5.1 and 5.2 cited for results in 5.3 and 5.4; a stale copy of an old README.
Fix	Rewritten from Chapter 5 and the recorded run.
Verified	Every figure traced to its table.

M12, M13 — Major

The trail inspector could not pass outside the author's machine.

Evidence	Tag never pushed; pandoc crash; check 4 misread patch ranges; check 14 replayed every file from the tag.
Fix	Loud failures; pandoc checked; ranges read; check 14 replays each file from the state its first logged patch began from.
Verified	Inspector passes every check, including check 14 for the first time since October.

M14 — Major

The submission Word file was the one artefact no gate inspected.

Evidence	Page numbers left as #; a failed LibreOffice step still exited 0; the file was overwritten in place.
Fix	Page numbers by default; failure on missing content or tools; atomic write with a CRC check; new inspector check 15.
Verified	Build and check 15 pass.

M15, M16 — Major

Two inspectors could pass vacuously or read the wrong file.

Evidence	CHECKSUMS.md described the other repository; concordance passed with zero references from another directory.
Fix	Checksums cover this repository's copies; concordance anchored to the repository and fails on zero.
Verified	Run from a foreign directory: refuses.

P2-M2 — Major

Chapter 5 said the reported run uses Synthea payloads.

Evidence	Tables 5.3 to 5.6 come from constructed payloads (43 bytes on average).
Fix	§5.2 corrected; Synthea serves §5.8 only.
Verified	Text checked against generate().

P2-M3 **Two Synthea cohorts were conflated.**

Major

Evidence	16 September cohort (1,006 bytes) and its 6 October regeneration (1,002 bytes, Table 5.7) described as one.
Fix	Both named in the provenance statement and the subset README, in both repositories.
Verified	Figures traced to their recorded runs.

P2-M4 **The cross-sector "no violations" did not test the whole log entry the § 17 limit reaches.**

Major

Evidence	After the three-year limit the accessor fields remain and the check returns true.
Fix	§6.10 states the narrower zero.
Verified	Reproduced at month 40.

> Fifteen minor findings were fixed as well, among them: decryption that crashed on an unauthenticated ciphertext, a Z3 run with no timeout, an exit status that ignored tampering, an app verdict that said "holds" on failure, a record strip drawn rather than computed, and wording that called synthetic payloads real. Two printed lines changed on purpose and were re-recorded; no figure in the thesis changed.

Part 3

Evidence map

Each load-bearing claim, the section that makes it, the code that checks it, and what fails if the code stops agreeing with the thesis. Proposition 4 is argued, not executed, and is listed so that the gap is visible.

Claim	What it says	Thesis	Checked by	Guarded by
Proposition 1	Under plaintext verifiability the three obligations are infeasible whenever a deadline falls inside the retention window.	§4.6	`check_semantics_I; brute_force_semantics_I; z3_check P1`	recorded run; cross-check test (31 cases); Z3 mutation
Proposition 2	Under accountability-preserving verifiability they are jointly satisfiable for every record, request pattern and floor.	§4.7	`check_semantics_II; V_II; integrity`	recorded run; 3 tamper tests; exit status
Proposition 3	A ceiling collides with a floor only if the ceiling ends no later than the floor.	§4.6	`z3_check P3; delta_witness`	Z3 with off-by-one mutation
Proposition 4	Moving a record out of the regulated environment meets the ceiling but not the right (stated premise).	§4.10	`argued, not executed`	premise listed in §3.7
Corollary 1.2	Infeasibility without any erasure request, on the broad reading of Art. 68(12).	§4.6, §5.4	`cor12 count in trf_checker`	ledger: 39 witnesses
95 / 90 of 200	Semantics I violations and records.	Table 5.3	`trf_checker.main`	byte-identical recorded run
138, 52 / 86, 0	Invalidations, their grounds, Semantics II violations.	Table 5.6	`apply_invalidation; check_semantics_II`	recorded run; ledger
200 of 200	Records verifying against the audit log root.	§5.7	`MerkleLog; integrity`	tamper tests must fail
Payload independence	No figure moves with real-format payloads.	Table 5.7	`synthea_layer`	exit status on divergence
Attested, not proven	Key destruction is simulated; the residue is pseudonymised, not anonymous.	§4.8, §4.9	`crypto_envelope; docstrings`	stated in code, app and thesis

> The viewer's claim ledger recomputes every Chapter 5 figure each time it opens, and an automated test fails if any of them, or any proposition the viewer quotes, departs from the thesis text.

Part 4, policy brief

Retention of the cross-border audit trail: two findings for the controller

For Helsedirektoratet (NCPeH controller), Datatilsynet, and the Ministry of Health and Care Services

Every cross-border exchange through MyHealth@EU leaves an audit record. Three obligations then act on that record at once: it must be kept, so it can be audited; the patient may ask for erasure (GDPR Article 17); and data in a Secure Processing Environment must be deleted within six months of the permit's end (EHDS Article 68(12)). No instrument says how these fit together.

1 **The six-year pilot period is a policy floor, not yet a legal one.**

Helsedirektoratet has confirmed that no eHDSI specification fixes a retention period and that the six years of the Norwegian pilot are its own decision as controller (Appendix D). The new MyHealth@EU implementing regulation, (EU) 2026/2083, requires the exchanges to be logged but also sets no period. An exemption from erasure under Article 17(3)(b) needs a legal obligation. Until Article 9 EHDS applies in March 2029, and beyond its 36 months after that, keeping the patient link against an erasure request may therefore have no secure legal basis.

2 **Keeping and erasing can both be met, if "verifiable" means accountable.**

If an audit record must stay readable to count as verifiable, the obligations cannot all be met whenever a deadline falls inside the retention period. If it is enough to keep who acted, when, a commitment to the content and a logged invalidation entry, they can always be met: the content goes at its deadline and the record stays checkable. The thesis specifies a mechanism for this and checks it in code on synthetic data.

Three things to decide

- Decide the production retention period with a stated legal basis, before go-live.
- Ask, or answer, whether an audit record whose content has been invalidated still satisfies a retention obligation.
- Clarify whether Article 68(12) reaches access logs kept at patient-record granularity.

Limits. Results come from a formal model checked on synthetic data, not from a deployed system. Key destruction is attested, not proven. The retained record is pseudonymised, not anonymous. The legal readings are the author's and are put to the authorities, not assumed.

Arshad Akhtar Abbasia, Høgskolen i Molde, November 2026. Thesis: *Verifiable Crypto-Erasure for Cross-Border Health Data Audit Trails under the European Health Data Space*.

Del 5, notat

Lagring av revisjonsloggen for grensekryssende utveksling: to funn for den dataansvarlige

Til Helsedirektoratet (dataansvarlig for NCPeH), Datatilsynet og Helse- og omsorgsdepartementet

Hver grensekryssende utveksling gjennom MyHealth@EU etterlater en revisjonspost. Tre plikter virker da samtidig på denne posten: den skal oppbevares, slik at den kan revideres; pasienten kan be om sletting (personvernforordningen artikkel 17); og data i et sikkert analyserom skal slettes senest seks måneder etter at tillatelsen er utløpt (EHDS artikkel 68(12)). Ingen rettsakt sier hvordan disse henger sammen.

1 **Pilotens seks år er et valgt minstekrav, ennå ikke et lovfastsatt.**

Helsedirektoratet har bekreftet at ingen eHDSI-spesifikasjon fastsetter en lagringstid, og at seks år i den norske utprøvingen er direktoratets egen beslutning som dataansvarlig (vedlegg D). Den nye gjennomføringsforordningen for MyHealth@EU, (EU) 2026/2083, krever at utvekslingene logges, men fastsetter heller ingen lagringstid. Unntaket fra sletting i artikkel 17 nr. 3 bokstav b forutsetter en rettslig forpliktelse. Inntil EHDS artikkel 9 gjelder fra mars 2029, og utover de 36 månedene den fastsetter, kan det derfor mangle et sikkert rettsgrunnlag for å beholde pasientkoblingen når pasienten ber om sletting.

2 **Oppbevaring og sletting kan begge oppfylles, dersom etterprøvbar betyr etterrettelig.**

Må en revisjonspost kunne leses for å regnes som etterprøvbar, kan pliktene ikke oppfylles samtidig når en frist faller innenfor lagringstiden. Er det nok å bevare hvem som handlet, når, en forpliktelse til innholdet og en logget ugyldiggjøring, kan de alltid oppfylles: innholdet slettes ved fristen, og posten kan fortsatt kontrolleres. Oppgaven beskriver en mekanisme for dette og kontrollerer den i kode på syntetiske data.

Tre ting å avklare

- Fastsett lagringstiden for produksjon med et uttrykkelig rettsgrunnlag før driftsstart.
- Avklar om en revisjonspost med ugyldiggjort innhold fortsatt oppfyller en oppbevaringsplikt.
- Avklar om artikkel 68(12) omfatter tilgangslogger som føres på nivå med den enkelte pasientjournal.

Begrensninger. Resultatene bygger på en formell modell kontrollert på syntetiske data, ikke på et system i drift. Sletting av nøkler er attestert, ikke bevist. Posten som beholdes, er pseudonymisert, ikke anonym. De rettslige tolkningene er forfatterens og legges fram for myndighetene, ikke forutsatt.

Arshad Akhtar Abbasia, Høgskolen i Molde, november 2026. Masteroppgave: *Verifiable Crypto-Erasure for Cross-Border Health Data Audit Trails under the European Health Data Space*.